

GUÍA METODOLÓGICA DETALLADA

Encuesta Integral de Ciberseguridad 2026

Versión: 1.0

Fecha: Enero 2026

Audiencia: Facilitadores, CISOs, Responsables de Análisis

TABLA DE CONTENIDOS

1. Introducción y Propósito
2. Modelo de Referencia Subyacente
3. Metodología GQM Aplicada
4. Proceso de Administración de la Encuesta
5. Puntuación e Interpretación
6. Cálculo del IGM (Índice de Gobernanza de Madurez)
7. Análisis de Brechas (Gap Analysis)
8. Validación de Respuestas
9. Generación de Reportes
10. Mejores Prácticas en Facilitación

1. INTRODUCCIÓN Y PROPÓSITO

Esta guía proporciona instrucciones detalladas para administrar, calificar y analizar la **Encuesta Integral de Ciberseguridad**, diseñada para evaluar la madurez organizacional en seis dominios críticos de ciberseguridad.

1.1 Objetivos de la Encuesta

La encuesta tiene tres objetivos primarios:

11. Evaluación de Línea Base: Establecer punto de referencia actual de madurez organizacional
12. Identificación de Gaps: Mapear diferencias entre estado actual y estado deseado
13. Priorización de Mejora: Guiar inversión en ciberseguridad con máximo ROI

1.2 Usuarios Objetivo

- CISOs y Responsables de Seguridad: Evaluación completa de programa
- Auditores Internos/Externos: Validación de cumplimiento regulatorio
- Consultores: Benchmark versus mejores prácticas industriales
- Analistas de Riesgo: Cuantificación de exposición de riesgo
- Directivos/Junta: Información sobre postura de riesgo cibernético

2. MODELO DE REFERENCIA SUBYACENTE

2.1 Mapeo a Frameworks Establecidos

Esta encuesta mapea a múltiples frameworks reconocidos:

Dominio Encuesta	NIST CSF 2.0	ISO 27001	COBIT 2019	CIS Controls
Gobernanza y Riesgo	GOVERN	A.5, A.6	EDM, APO	Foundation
Gestión Vulnerabilidades	IDENTIFY, PROTECT	A.12 (Asset Mgmt)	BAI	2-6
Pruebas Penetración	IDENTIFY, PROTECT	A.14 (Assessments)	DSS	1
Monitoreo SIEM	DETECT	A.16 (Logging)	DSS, BAI	8, 9
Respuesta Incidentes	RESPOND	A.16.1	DSS	17, 18
Capacitación	GOVERN, PROTECT	A.6	APO, BAI	15

2.2 Escala de Madurez (Basada en CMMI)

Cada pregunta utiliza escala Likert de 5 niveles derivada de **Capability Maturity Model Integration (CMMI)**:

Nivel 1 - Inicial (Ad-hoc)

- └ Capacidades no documentadas
- └ Resultados impredecibles
- └ Dependencia de individuos

Nivel 2 - Repetible (Managed)

- └ Procesos básicos documentados
- └ Resultados parcialmente predecibles
- └ SLAs informales

Nivel 3 - Definido (Defined)

- └ Procesos formalizados
- └ Documentación completa
- └ Cumplimiento de SLAs

Nivel 4 - Gestionado (Quantitatively Managed)

- └ Procesos automatizados
- └ Métricas cuantitativas
- └ Mejora basada en datos

Nivel 5 - Optimizado (Optimizing)

- └ Mejora continua con IA/ML
- └ Predicción de riesgos
- └ Adaptación automática a amenazas

3. METODOLOGÍA GQM APLICADA

3.1 Estructura Goal-Question-Metric

Cada sección de la encuesta sigue estructura **GQM (Goal-Question-Metric)**:

EJEMPLO: Gestión de Vulnerabilidades

GOAL: "Reducir riesgo de explotación de vulnerabilidades a través de priorización basada en evidencia y remediación eficiente"

QUESTIONS:

- ¿Existen procesos formales de escaneo?
- ¿Está integrado EPSS en priorización?
- ¿Cómo es el MTTR para vulnerabilidades críticas?
- ¿Se valida remediación?

METRICS:

- Cobertura de escaneo (% attack surface)
- EPSS adoption rate (% CVEs puntuadas con EPSS)
- MTTR (Media aritmética en días)
- Remediation validation rate (% re-scans confirmados)

3.2 Jerarquía de Preguntas

Las 42 preguntas de dominio se organizan jerárquicamente:

- Nivel 1: Preguntas sobre CAPACIDAD (¿existe?)
- Nivel 2: Preguntas sobre COBERTURA (¿cuán extenso?)
- Nivel 3: Preguntas sobre EFECTIVIDAD (¿qué tan bien funciona?)
- Nivel 4: Preguntas sobre AUTOMATIZACIÓN (¿qué está automatizado?)
- Nivel 5: Preguntas sobre OPTIMIZACIÓN (¿evoluciona automáticamente?)

4. PROCESO DE ADMINISTRACIÓN

4.1 Pre-Encuesta (Semana 1)

14. Identificar Respondientes:
15. Mínimo 1 persona por dominio (idealmente 2-3 para validación)
16. Preferentemente personas con 2+ años en rol actual
17.
Mezcla de perspectivas: técnicos + gestión
18.
Preparar Contexto:
19. Compartir objetivos de encuesta
20. Explicar que no es "auditoría" sino "evaluación colaborativa"
21.
Solicitar honestidad (puntuaciones bajas llevan a mejores planes de mejora)
22.
Proporcionar Recursos:
23. Enviar encuesta en formato digital (Google Forms, Qualtrics, o PDF)
24. Compartir esta Guía Metodológica
25. Proporcionar glosario de términos técnicos

Mezcla de perspectivas: técnicos + gestión

Preparar Contexto:

Solicitar honestidad (puntuaciones bajas llevan a mejores planes de mejora)

Proporcionar Recursos:

4.2 Administración (Semanas 2-4)

Opción A: Auto-Administración (Asincrónica)

- Respondientes completan encuesta de forma independiente
- Plazo: 2 semanas
- Facilitador disponible para aclaraciones por email/chat
- Ventaja: Permite reflexión profunda
- Desventaja: Respuestas menos consistentes

Opción B: Sesión Facilitada (Sincrónica)

- Facilitador guía grupo a través de encuesta
- Duración: 2 sesiones de 2-3 horas cada una (pausas incluidas)
- Formato: Workshop o videoconferencia

- Ventaja: Clarificación inmediata, consenso en tiempo real
- Desventaja: Requiere coordinación de horarios

Recomendación: Opción B (Sesión Facilitada) para máxima calidad y consenso

4.3 Validación en Tiempo Real (Sesión Facilitada)

Durante sesión, facilitador debe:

26. Explorar evidencia de apoyo para cada respuesta:

'''

Pregunta: "¿EPSS integrado en herramienta VM?"

Respuesta propuesta: Nivel 4 (EPSS con actualizaciones diarias)

Validación:

- ¿Cuál es la herramienta VM? (Qualys, Tenable, Rapid7, etc.)
- ¿EPSS se actualiza realmente diario? (Verificar configuración)
- ¿Hay alertas automatizadas basadas en EPSS? (Mostrar ejemplo)
- Evidencia: Screenshot, configuración, logs

'''

27. Resolver inconsistencias:

28. Si múltiples respondientes dan puntuaciones diferentes, discutir hasta consenso

- 29.

Documentar razones de desacuerdos para contexto posterior

- 30.

Capturar contexto cualitativo:

31. Notas sobre limitaciones operativas

32. Factores externos (presupuesto, personal, regulación)

33. Planes ya conocidos de mejora

Documentar razones de desacuerdos para contexto posterior

Capturar contexto cualitativo:

5. PUNTUACIÓN E INTERPRETACIÓN

5.1 Escala de Puntuación Numérica

Asignar valores numéricos a niveles:

Nivel	Valor	Interpretación
1 - Inicial	1.0	Capacidad mínima
2 - Repetible	2.0	Capacidad básica
3 - Definido	3.0	Capacidad establecida
4 - Gestionado	4.0	Capacidad avanzada
5 - Optimizado	5.0	Capacidad de clase mundial

5.2 Puntuación a Nivel de Pregunta

Para cada pregunta:

- **Valor Primario:** Nivel seleccionado (1-5)
- **Ponderación:** Todas las preguntas pesan igual ($1/42 = 2.38\%$ cada una)
- **Evidencia:** Notas sobre fuentes de validación

5.3 Puntuación a Nivel de Dominio

Para cada dominio, calcular **promedio aritmético**:

$$\text{Puntuación Dominio} = \Sigma(\text{Puntuaciones Preguntas}) / \text{Número de Preguntas}$$

Ejemplo - Gestión de Vulnerabilidades (7 preguntas):

GV-01: Nivel 3 (3.0)
GV-02: Nivel 3 (3.0)
GV-03: Nivel 2 (2.0)
GV-04: Nivel 3 (3.0)
GV-05: Nivel 4 (4.0)
GV-06: Nivel 3 (3.0)
GV-07: Nivel 2 (2.0)

$$\text{Puntuación GV} = (3+3+2+3+4+3+2)/7 = 20/7 = 2.86 \text{ (redondeado a 2.9)}$$

5.4 Puntuación a Nivel de Organización (IGM)

IGM (Índice de Gobernanza de Madurez) = Promedio de 6 dominios:

$$\text{IGM} = (\text{GR} + \text{GV} + \text{PT} + \text{SI} + \text{RI} + \text{CC}) / 6$$

Escala de Interpretación:

1.0 - 1.5: Crítica

- └ Riesgos significativos no mitigados
- └ Exposición elevada a ataques
- └ Urgencia inmediata de mejora

1.5 - 2.5: Débil

- └ Controles básicos inconsistentes
- └ Vulnerabilidades significativas
- └ Mejora necesaria en 12-18 meses

2.5 - 3.5: Aceptable

- └ Controles establecidos con gaps
- └ Cumplimiento regulatorio parcial
- └ Hoja de ruta de mejora 18-24 meses

3.5 - 4.5: Buena

- └ Programa maduro y proactivo
- └ Cumplimiento regulatorio completo
- └ Mejora incremental vs transformacional

4.5 - 5.0: Excelente

- └ Programa de clase mundial
- └ Anticipación de amenazas emergentes
- └ Benchmark de industria

6. CÁLCULO DEL IGM

6.1 Matriz de Puntuación

Crear matriz de tabulación:

MATRIZ DE PUNTUACIÓN - ENCUESTA CIBERSEGURIDAD [Org: ____] [Fecha: ____]

GOBERNANZA Y RIESGO (GR)

- GR-01: Política de Gestión Riesgos: ____ [Evidencia: ____]
- GR-02: Conformidad Regulatoria: ____ [Evidencia: ____]
- GR-03: CISO Autonomía: ____ [Evidencia: ____]
- GR-04: Riesgos Terceros: ____ [Evidencia: ____]

Promedio GR: ____

GESTIÓN VULNERABILIDADES (GV)

- GV-01: Estructura Programa: ____
- GV-02: Cobertura Escaneo: ____
- GV-03: Adopción EPSS: ____
- GV-04: Priorización Integrada: ____
- GV-05: MTTR Críticas: ____
- GV-06: Validación Remediación: ____
- GV-07: Eficiencia Operacional: ____

Promedio GV: ____

... [Continuar para PT, SI, RI, CC] ...

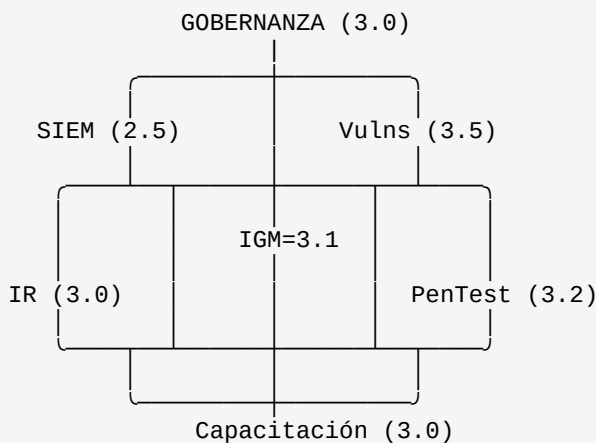
IGM FINAL = (GR + GV + PT + SI + RI + CC) / 6 = ____

CLASIFICACIÓN: [] Crítica [] Débil [] Aceptable [] Buena [] Excelente

6.2 Visualización de Resultados

Crear gráficos **radar** (spider chart) para visualización:

Ejemplo Radar Chart (ASCII):



7. ANÁLISIS DE BRECHAS (GAP ANALYSIS)

7.1 Definir Estado Deseado (Target Profile)

Antes de análisis de brechas, definir **Target Profile** (estado deseado):

Organización Tipo	Target IGM	Plazo	Justificación
Start-up / Pre-Series	2.5-3.0	24 meses	Cumplimiento mínimo + prevención de riesgos básicos
PME en crecimiento	3.0-3.5	18-24 meses	Cumplimiento regulatorio + programa operativo
Enterprise Sector Crítico	3.8-4.2	12-18 meses	Anticipación de amenazas + resiliencia
Institución Financiera	4.2-4.5	12-18 meses	Cumplimiento regulatorio estricto + avanzado
Agencia Ciberseguridad	4.5-5.0	Continuo	Excelencia de clase mundial

7.2 Cuantificar Gaps

Para cada dominio:

$$\text{Gap} = \text{Target Score} - \text{Current Score}$$

Ejemplo:

Target IGM: 3.5 (Enterprise sector crítico)

Current IGM: 2.8 (estado actual)

Gap total: 0.7 puntos (20% de mejora requerida)

Desglose por dominio:

Dominio	Actual	Target	Gap	% Mejora	Prioridad
GR	3.0	3.8	0.8	26.7%	Alta
GV	2.9	3.9	1.0	34.5%	Máxima
PT	2.5	3.5	1.0	40.0%	Máxima
SI	2.2	3.8	1.6	72.7%	Crítica
RI	3.1	3.6	0.5	16.1%	Media
CC	2.6	3.5	0.9	34.6%	Alta

7.3 Priorización de Acciones (MoSCoW + Esfuerzo)

Matriz de priorización considerando **esfuerzo** e **impacto**:

IMPACTO (Beneficio en IGM)

Alto	RÁPIDAS GANANCIAS (Haz primero) • Integrar EPSS • Mejorar MTTR • Capacitación phishing	PROYECTOS ESTRATÉGICOS (Planifica, ejecuta) • Implementar SIEM • Red team program • Automatización SOAR
Bajo	LLENA TIEMPO • Actualizar políticas • Reporte cosmético	EVITA / DELEGA • Mejoras cosméticas • Perfeccionar lo menor
	Bajo	Alto

Clasificación (MoSCoW):

MUST (Debe): Llevar IGM de 2.8 a 3.0+ (gaps críticos SI, GV)

SHOULD (Debería): Llevar IGM a 3.5+ (mejora sistemática)

COULD (Podría): Llevar IGM a 4.0+ (excelencia)

WON'T (No): Optimizaciones menores, cambios cosméticos

8. VALIDACIÓN DE RESPUESTAS

8.1 Criterios de Validez

Cada respuesta debe satisfacer criterios de **Validez de Contenido**:

PREGUNTA GVPASSA: ¿Adopción EPSS?

Respuesta propuesta: Nivel 4 (EPSS diario, automatizado)

VALIDACIÓN:

- ¿Tiene evidencia documentada? (Sí/No)
 - Requerido: Screenshots de herramienta, logs de ingesta EPSS
- ¿Es consistente con preguntas relacionadas?
 - GV-03: Adopción EPSS = Nivel 4
 - GV-04: Priorización integrada = ¿Mínimo Nivel 3?
 - GV-01: Programa estructura = ¿Mínimo Nivel 3?
 - Si hay incoherencia: INVESTIGAR
- ¿Es realista según contexto organizacional?
 - Empresa pequeña claiming Nivel 5 = Potencial sesgo
 - Enterprise con Nivel 1 = Potencial subestimación
- ¿Hay evidencia de "saltar niveles"?
 - Ej: Nivel 5 (automatizado) sin Nivel 3 (documentado)
 - Rojo bandera: Requiere exploración

8.2 Preguntas de Sondeo (Probe Questions)

Cuando se identifique inconsistencia, usar preguntas de sondeo:

ESCENARIO: Respondiente reclama Nivel 4 para MTTR (5-7 días) pero Nivel 1 para EPSS.

SONDEO:

- "¿Cómo prioriza vulnerabilidades sin EPSS?"
└ Probable respuesta: "Por CVSS"
- "¿Qué % de vulnerabilidades CVSS ≥ 7.0 tiene típicamente?"
└ Probable respuesta: ">500 mensuales"
- "¿Cómo remedia >500 vulnerabilidades en 5-7 días?"
└ DESCUBRE: Respondiente está subestimando MTTR
└ ACCIÓN: Revisar ambas puntuaciones hacia abajo

8.3 Matriz de Validación Cruzada

Validar respuestas internas mediante matriz:

MATRIZ DE COHERENCIA - GESTIÓN VULNERABILIDADES

	GV-01 Programa	GV-03 EPSS	GV-05 MTTR	GV-07 Eficiencia
GV-01 Programa	X	$\geq L2$	$\geq L2$	$\geq L2$
GV-03 EPSS	$\geq L2$	X	$\geq L3$	$\geq L2$
GV-05 MTTR	$\geq L2$	$\geq L3$	X	$\geq L3$
GV-07 Eficiencia	$\geq L2$	$\geq L2$	$\geq L3$	X

Leyenda: $\geq L2$ = Debe ser mínimo Nivel 2 si este es Nivel X
 $\geq L3$ = Debe ser mínimo Nivel 3 si este es Nivel X

VALIDACIÓN:

Si GV-05 (MTTR) = 4.0 pero GV-03 (EPSS) = 1.0 → Inconsistencia

Si GV-01 (Programa) = 2.0 pero GV-07 (Eficiencia) = 4.0 → Imposible

9. GENERACIÓN DE REPORTES

9.1 Estructura de Reporte Ejecutivo

Reporte debe contener:

REPORTE EJECUTIVO - ENCUESTA CIBERSEGURIDAD [ORG]

Fecha: ____ | Periodo Evaluado: ____ | Facilitador: ____

SECCIÓN 1: RESUMEN EJECUTIVO (1 página)

- └ IGM General
- └ Puntuación por dominio (tabla)
- └ Gráfico radar
- └ Estado general (Crítica/Débil/Aceptable/Buena/Excelente)

SECCIÓN 2: HALLAZGOS CLAVE (2 páginas)

- └ Fortalezas identificadas (top 3)
- └ Brechas críticas (top 3)
- └ Riesgos asociados a brechas
- └ Oportunidades de mejora rápida

SECCIÓN 3: ANÁLISIS DETALLADO (5-7 páginas)

- └ Gobernanza y Riesgo
 - └ Puntuación: ____ | Fortalezas | Gaps | Recomendaciones
- └ Gestión Vulnerabilidades
 - └ [Ídem]
- └ Pruebas Penetración
 - └ [Ídem]
- └ Monitoreo SIEM
 - └ [Ídem]
- └ Respuesta Incidentes
 - └ [Ídem]
- └ Capacitación Seguridad
 - └ [Ídem]

SECCIÓN 4: HOJA DE RUTA DE MEJORA (3-4 páginas)

- └ Timeline de 18-24 meses
- └ Matriz MoSCoW de iniciativas
- └ Presupuesto estimado
- └ Roles y responsabilidades
- └ KPIs de seguimiento

SECCIÓN 5: APÉNDICES

- └ Respuestas detalladas (tabla)
- └ Matriz de validación
- └ Glosario de términos
- └ Referencias normativas

9.2 Narrativa por Dominio - Plantilla

GESTIÓN DE VULNERABILIDADES

****Puntuación Dominio:**** 2.9 / 5.0 (Débil, por debajo de target 3.8)

Fortalezas

- **Escaneo infraestructura establecido**** (GV-01: Nivel 3)
 - Escaneos semanales automatizados
 - Roles y responsabilidades documentados
 - SLAs por severidad definidos
- **Priorización mejorando**** (GV-03: Nivel 2)
 - Piloto EPSS iniciado Q4 2025
 - Algunos equipos integrando scores

Brechas Críticas

- **EPSS subutilizado**** (GV-03: Nivel 2, target Nivel 3-4)
 - EPSS manual, sin integración en herramienta
 - <30% de vulnerabilidades puntuadas
 - ****Impacto:**** Desperdicio de 50% de esfuerzo en remediación
- **MTTR Críticas prolongado**** (GV-05: Nivel 2, target Nivel 4)
 - Promedio 35 días para "Críticas"
 - SLA Nivel 4 requiere <7 días
 - ****Impacto:**** Exposición 5x más larga de lo deseado

Riesgos

- ****Riesgo Operacional:**** Probabilidad 60% de explotación de vuln crítica dentro 30 días (EPSS promedio 0.72 para vulnerabilidades sin parchear >30 días)
- ****Riesgo Regulatorio:**** Incumplimiento NIS2 Art 21(E) si no hay priorización evidenciada

Recomendaciones (Prioridad Alta)

****RÁPIDA GANANCIA (Q1 2026):****

- Implementar integración EPSS en herramienta VM (Qualys/Tenable)
 - Esfuerzo: 1-2 semanas
 - Impacto IGM: +0.3 puntos
 - ROI: Filtrado 50% de ruido, MTTR -40%
- Revisar SLA de MTTR críticas
 - Asignar recursos adicionales a remediación
 - Automatizar parching donde posible

****PROYECTO ESTRATÉGICO (Q2-Q3 2026):****

- Implementar SOAR para orquestación de remediación
 - Esfuerzo: 6-8 semanas
 - Impacto IGM: +0.4 puntos
 - ROI: Remediación automatizada 70%+ de vulnerabilidades Nivel 3-4

10. MEJORES PRÁCTICAS EN FACILITACIÓN

10.1 Preparación de Sesión

2 Semanas Antes:

- Confirmar asistentes (mínimo 1 por dominio, máximo 2)

- Enviar encuesta para lectura previa
- Compartir matriz de contexto organizacional

1 Semana Antes:

- Verificar asistentes entendieron estructura
- Preparar room setup (pizarra, proyector)
- Descargar herramienta de scoring (Excel/Google Sheets)

1 Día Antes:

- Test técnico (videoconferencia, conexión)
- Preparar backup de encuesta impresa
- Revisar frameworks referencia (NIST, ISO, etc.)

10.2 Durante la Sesión

Apertura (10 min):

"Buenos días. Esta sesión evalúa madurez de ciberseguridad en 6 áreas. No es auditoría—es colaborativa. Queremos honestidad: scores bajos llevan a planes de mejora mejor enfocados. Seguiremos estructura: 45 min preguntas + 15 min análisis por sesión."

Exploración de Preguntas (7-8 min c/u):

34. Lea pregunta completa en voz alta
35. Permita reflexión silenciosa (30 seg)
36. Pregunte respuesta inicial propuesta + por qué
37. Sondee con preguntas de apoyo:
38. "¿Tienes evidencia documentada?"
39. "¿Cuál fue la última actualización?"
40. "¿Todo el equipo lo usa consistentemente?"
41. Resuelva discrepancias (si hay múltiples respondientes)
42. Capte notas sobre contexto limitante

Cierre (10 min):

"Hemos completado [6 dominios x 7 preguntas = 42 evaluaciones]. Puntuación inicial IGM: 2.8. Análisis detallado en reporte la próxima semana. ¿Preguntas?"

10.3 Manejo de Sesgos

Sesgo 1: Over-inflated Scores (Sesgo de Deseabilidad Social)

Síntoma: Respondientes califican como Nivel 5 cuando evidencia sugiere Nivel 2-3

Mitigación:

- "¿Eso está 100% automatizado? Muéstrame un ejemplo."

- Revisar logs/screenshots de herramienta
- Preguntar sobre excepción: "¿Siempre ocurre así o hay excepciones?"

Sesgo 2: Under-inflated Scores (Síndrome del Impostor)

Síntoma: Respondientes dicen "somos malos" cuando tienen programas decentes

Mitigación:

- "¿Tienes políticas documentadas?" → "Sí" = Mínimo Nivel 2
- Usar preguntas de referencia: "¿Comparado a industria, dónde te ves?"
- Referir a benchmarks externos

Sesgo 3: Inconsistencia (Conflicto de Información)

Síntoma: Respondiente A dice Nivel 3, Respondiente B dice Nivel 1

Mitigación:

- "Veo perspectivas diferentes. ¿Qué dinámica causa esto?"
- Descubre si es: (a) desconocimiento, (b) definiciones diferentes, (c) variación real
- Consensuar en Nivel 2 si hay desacuerdo genuino → conservador pero válido

CONCLUSIÓN

Esta guía proporciona rigor metodológico para administrar, punuar y actuar sobre resultados de encuesta de ciberseguridad. El éxito depende de:

43. Honestidad en respuestas (no solo políticas ideales, sino realidad operativa)
44. Evidencia documentada (no especulación)
45. Perspectivas múltiples (validación cruzada)
46. Contexto organizacional (no benchmarking ciego)
47. Seguimiento accionable (convertir insights en mejora real)

*Guía desarrollada por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*